

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA5115

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I M Nishanth certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: M Nishanth

Annexure A
Industry Problem-Solving Task

1. A multinational enterprise is deploying IPSec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
 - B. Design packet flow with appropriate IPSec modes (transport/tunnel)
 - C. Justify protocol selection for different data types
 - D. Evaluate performance vs security trade-offs
-
2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
- B. Design an automated key management mechanism (e.g., IKE-based)
- C. Propose a strategy for key renewal and revocation
- D. Evaluate scalability and fault tolerance

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification

D. Design a high-level implementation workflow

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
 - B. Analyze email headers for spoofing indicators
 - C. Design an improved detection model (rule-based or ML-based)
 - D. Evaluate effectiveness and false positive handling
5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process
- C. Propose secure certificate storage and management practices
- D. Recommend improvements for user awareness and system configuration

SIMATS ENGINEERING

ASSESSMENT TOOL 2 — INDUSTRY PROBLEM-SOLVING TASK

Question 1: IPSec AH and ESP Configuration for Branch Office Communication

A multinational enterprise deploying IPSec between branch offices over the public internet must decide how Authentication Header (AH) and Encapsulating Security Payload (ESP) are applied so that both integrity and confidentiality are achieved for the right traffic types, without unnecessary overhead.

A. Traffic Requiring AH, ESP, or Both

- AH-suitable traffic: Traffic where origin authentication and header/payload integrity matter but confidentiality is not required — e.g., internal network management traffic (SNMP, syslog) or routing protocol exchanges (OSPF/BGP over IPSec) where visibility for troubleshooting is acceptable but tampering must be detected.
- ESP-suitable traffic: Any traffic carrying sensitive business data crossing the public internet — customer records, financial transactions, HR data, VoIP calls between branches — requires confidentiality (encryption) in addition to integrity, making ESP with integrated authentication the correct choice.
- Both / ESP-with-authentication: In practice, standalone AH is rarely deployed today because it authenticates the outer IP header, which breaks under Network Address Translation (NAT) — a near-universal requirement for internet-facing branch gateways. The modern equivalent of 'AH + ESP' is ESP configured with its own integrated authentication (ESP-HMAC-SHA256 or AES-GCM), which provides confidentiality, integrity, and authentication in a single, NAT-traversable protocol. This should be the default for essentially all branch-to-branch traffic.

B. Packet Flow Design with IPSec Modes

- Tunnel mode is appropriate here: since traffic passes between branch office gateways over the untrusted public internet, the entire original IP packet (header + payload) must be encapsulated inside a new outer IP packet, hiding internal addressing schemes from the public network.
- Packet flow: a host in Branch A's internal network sends a packet to a host in Branch B → Branch A's IPSec gateway intercepts it, encrypts/authenticates the original packet, and wraps it in a new outer IP header addressed from Gateway A's public IP to Gateway B's public IP (ESP tunnel mode) → the packet transits the public internet → Branch B's gateway verifies and decrypts it, strips the outer header, and forwards the original packet into Branch B's internal network.

- Transport mode should be reserved for host-to-host protection within an already-trusted network segment (e.g., securing traffic between two specific servers on the same internal network), not for the branch-to-branch public internet leg, since it does not hide the original internal IP addresses.

C. Protocol Selection Justification by Data Type

- Sensitive financial/customer data between branches: ESP, tunnel mode, AES-256-GCM (combined encryption + authentication) — confidentiality is mandatory given regulatory obligations around customer data in transit over a public network.
- Routing/network-management traffic: ESP with NULL encryption and HMAC authentication (or AH where NAT is not present, e.g., over a dedicated MPLS segment) — integrity/authentication needed, but encrypting purely operational traffic adds unnecessary overhead.
- Real-time VoIP between branches: ESP transport or tunnel mode using AES-GCM (an AEAD cipher), chosen specifically because it combines encryption and authentication in a single pass, minimizing the added latency that is critical for voice quality.
- Bulk file transfer / backup replication between data centers: ESP tunnel mode with strong encryption (AES-256); since these transfers are typically less latency-sensitive, the priority is confidentiality of potentially large, sensitive data sets.

D. Performance vs Security Trade-offs

- AH offers lower processing overhead (no encryption) but provides no confidentiality and is NAT-incompatible — a poor fit for internet-facing branch links carrying sensitive data despite the performance benefit.
- ESP with separate encryption and HMAC authentication increases CPU load (two cryptographic passes) and adds tunnel-mode header overhead (roughly 20–38 extra bytes depending on algorithms), slightly reducing effective throughput and increasing latency.
- Using AEAD ciphers such as AES-GCM reduces this overhead by performing encryption and authentication in one combined operation, offering close to the performance of encryption-only while retaining full authentication — this is the recommended trade-off point for most enterprise branch links.
- Hardware cryptographic acceleration (AES-NI on gateway CPUs, or dedicated crypto ASICs on enterprise VPN appliances) largely offsets the remaining overhead, meaning the security benefit of ESP with strong ciphers is achievable without a materially worse user experience on modern hardware.

- Recommendation: standardize on ESP tunnel mode with AES-256-GCM for all branch-to-branch traffic as the default balanced choice, reserving lighter-weight, authentication-only configurations only for non-sensitive operational traffic where confirmed appropriate.

Question 2: Automated Security Association and Key Management for IPSec

An organization suffering from expired or mismatched IPSec keys needs an automated, scalable approach to Security Association (SA) lifecycle management rather than continued manual configuration.

A. Current SA Lifecycle Issues

- Manually configured pre-shared keys (PSKs) are prone to typos and mismatches across sites, and are rarely rotated because rotation requires coordinated manual changes at both ends simultaneously.
- SAs have fixed lifetimes (time-based or traffic-volume-based); without automated renewal, an SA can expire mid-session, abruptly dropping the VPN tunnel and disrupting branch connectivity.
- There is typically no centralized visibility into SA status across many branch gateways, so administrators are often unaware an SA is approaching expiry until the tunnel has already failed.
- Long-lived static keys, if ever compromised, expose all traffic protected under that key with no forward secrecy, since the same key material may have been reused across many sessions.

B. Automated Key Management Mechanism (IKE-Based)

- Adopt IKEv2 as the standard key-management protocol: IKEv2's IKE_SA_INIT and IKE_AUTH exchanges establish a secure, authenticated control channel between gateways automatically, without manual per-session key entry.
- Use the CREATE_CHILD_SA exchange within IKEv2 to automatically negotiate and periodically rekey the actual IPSec (ESP) SAs before their configured lifetime expires, eliminating manual rekeying and the downtime windows it causes.
- Replace static pre-shared keys with certificate-based authentication issued from an enterprise Public Key Infrastructure (PKI), allowing each branch gateway to authenticate using its own certificate rather than a shared secret that must be manually distributed and kept in sync.
- Enable Perfect Forward Secrecy (PFS) via a Diffie-Hellman group in the IKE policy, so each rekey generates fresh key material independent of previous keys, limiting the impact of any future key compromise to a single session window.

C. Key Renewal and Revocation Strategy

- Configure conservative, consistent SA lifetimes across all gateways (e.g., time-based renewal well before a hard expiry, such as rekeying at 90% of the lifetime) so IKEv2 negotiates new key material with overlap, avoiding any connectivity gap.
- Tie gateway certificate issuance to the enterprise PKI with automated renewal (e.g., via SCEP/EST auto-enrollment) well ahead of certificate expiry, removing the manual tracking burden entirely.
- Maintain a CRL/OCSP revocation infrastructure so that a compromised or decommissioned branch gateway's certificate can be revoked immediately, blocking it from establishing new SAs without needing to touch every other gateway's configuration.
- Centralize IKE/IPSec policy distribution (e.g., via a VPN policy/orchestration server) so lifetime, cipher, and PFS settings remain consistent across all branches rather than drifting through manual per-site configuration.

D. Scalability and Fault Tolerance Evaluation

- Certificate-based IKEv2 authentication scales far better than manually distributed PSKs as branch count grows, since adding a new site only requires issuing it a certificate from the existing PKI rather than distributing and tracking a new shared secret to every peer.
- Dynamic VPN topologies (e.g., DMVPN or hub-and-spoke with on-demand spoke-to-spoke tunnels) reduce the number of manually configured tunnel pairs compared to a full mesh, improving scalability as the branch count increases.
- Deploying redundant, high-availability VPN gateway pairs at each site prevents a single gateway failure from taking down branch connectivity, and centralized SA/certificate monitoring enables proactive alerts before problems cause outages.
- Centralized logging and dashboarding of SA and certificate status across all branches allows administrators to catch anomalies (e.g., an unusually short-lived SA suggesting instability) before they escalate to full outages.

Question 3: PGP vs S/MIME for Secure Financial Email Communication

A financial services company needs to secure sensitive transactional email and must choose between PGP and S/MIME based on usability, scalability, and how well each integrates with enterprise infrastructure.

A. Comparison in Real-World Deployment Scenarios

- PGP relies on a decentralized model where users generate and exchange keys directly or via public keyservers; it is popular in open-source and individual/technical communities but is less commonly adopted as a centrally managed enterprise standard.
- S/MIME relies on X.509 certificates issued through a hierarchical Certificate Authority (CA) structure and is natively supported by mainstream enterprise mail clients (Outlook, Apple Mail, most mobile mail apps) without requiring third-party plugins in most modern deployments.
- Usability: S/MIME is generally easier for non-technical staff since certificate handling can be made transparent through integration with existing corporate identity systems (e.g., Active Directory), while PGP typically requires manual key generation, exchange, and plugin installation (e.g., GPG4Win, Mailvelope), creating a steeper learning curve.
- Scalability: S/MIME scales more smoothly in a large enterprise because certificate issuance, renewal, and revocation are centrally managed through the existing PKI, whereas PGP's web-of-trust becomes difficult to manage consistently as the number of users and their individually signed trust relationships grows.

B. Key Management and Trust Models

- PGP uses a 'web of trust': individual users sign each other's public keys, and trust is subjective and distributed with no central authority — workable for small, technically engaged groups but difficult to govern or audit at enterprise scale.
- S/MIME uses a hierarchical trust model: a Root CA certifies Intermediate CAs, which issue end-entity certificates to individual users; trust decisions are made by validating a certificate chain up to a pre-trusted root, which supports centralized policy enforcement, consistent auditing, and clear accountability — all important for a regulated financial environment.

C. Recommendation with Justification

S/MIME is recommended as the primary standard for this financial services company, for the following reasons:

- It integrates directly with the organization's existing enterprise PKI and directory services (Active Directory/LDAP), reducing deployment friction.
- Its hierarchical CA trust model aligns with regulatory and audit requirements common in financial services, since certificate-bound identities support clear non-repudiation and traceability for sensitive transactions.

- Native client support significantly reduces end-user training overhead and IT support burden compared to PGP's plugin-based workflow.
- Centralized revocation (via CRL/OCSP) allows rapid response when an employee's certificate must be invalidated, such as during offboarding or a suspected compromise — a capability that is operationally simpler than coordinating web-of-trust revocation in PGP.
- PGP may still be retained selectively for secure communication with external technical partners who already use it, but it should not replace S/MIME as the internal enterprise standard.

D. High-Level Implementation Workflow

- 1. Establish or extend the enterprise PKI (internal CA, or a trusted commercial CA) to support S/MIME certificate issuance.
- 2. Issue S/MIME certificates to employees tied to verified corporate identity, using automated enrollment integrated with Active Directory/LDAP.
- 3. Deploy certificates to end-user mail clients (desktop and mobile) via centralized configuration management (Group Policy, MDM profiles).
- 4. Configure mail servers/gateways to enforce S/MIME signing on all outbound transactional email and require encryption for messages classified as confidential.
- 5. Deploy OCSP/CRL infrastructure so clients perform real-time revocation checks before trusting a certificate.
- 6. Train employees to recognize signed/encrypted message indicators and understand certificate renewal processes.
- 7. Continuously monitor and audit S/MIME usage and compliance through email gateway logs to confirm policy adherence.

Question 4: Advanced Phishing and Spam Detection Strategy

A company's basic email filtering is failing to keep pace with rising phishing and spam attacks, requiring analysis of the current system's weaknesses and a redesigned detection strategy combining header analysis and content analysis.

A. Limitations of Existing Filtering Techniques

- Basic filters often rely on static blacklists and simple keyword matching, which are easily bypassed through minor wording changes, URL obfuscation, or image-based spam content that contains no matchable text.

- Most basic filters do not verify sender authenticity through SPF, DKIM, or DMARC alignment, allowing spoofed 'From' addresses to reach the inbox even when the sending infrastructure is clearly unauthorized for that domain.
- Signature-based detection inherently lags behind novel, zero-day phishing campaigns since it can only catch patterns it has already seen.
- Purely content/keyword-based approaches struggle to detect socially engineered but linguistically clean attacks such as Business Email Compromise (BEC), where the email contains no obvious 'spam' language at all.

B. Email Header Analysis for Spoofing Indicators

- Verify SPF (Sender Policy Framework) alignment — confirm the sending mail server's IP is authorized for the claimed sending domain.
- Validate DKIM signatures — confirm the message body and key headers were not altered in transit and that the signature genuinely corresponds to the claimed sending domain.
- Check DMARC policy compliance — confirm SPF/DKIM results align with the visible 'From' header domain, and enforce the domain owner's declared policy (reject/quarantine) on failures rather than silently delivering the message.
- Inspect the Received: header chain for inconsistent or suspicious relay hops and mismatched reverse-DNS records that suggest the message did not originate where it claims.
- Flag mismatches between the Reply-To and From domains, and detect display-name spoofing (e.g., a familiar executive's name paired with an unrelated external domain).

C. Improved Detection Model Design (Hybrid Rule-Based + ML)

- Rule-based layer: automatic SPF/DKIM/DMARC verification, domain/URL reputation blocklist checks, and attachment-type risk rules (e.g., flag executable attachments disguised with document icons).
- Machine-learning layer: a content classifier (starting from a baseline model such as Naive Bayes or SVM, progressing to a transformer-based model as data volume grows) trained on email body text to detect urgency language, credential-harvesting phrasing, and requests for unusual actions (wire transfers, gift cards, credential entry).
- Behavioral features: sender-recipient relationship anomalies (e.g., first-time sender requesting a financial action), unusual sending time patterns, and link-redirect-chain analysis to detect cloaked malicious URLs.

- Combine rule-based flags and the ML model's probability score into a single ensemble risk score used to route messages to allow, warning-banner, quarantine, or block actions based on configurable thresholds.

D. Effectiveness Evaluation and False Positive Handling

- The layered design reduces false negatives, since sophisticated phishing that evades keyword rules can still be caught by header authentication checks or the ML content model, and vice versa.
- Maintain a continuous feedback loop where users can report false positives and false negatives, feeding corrected labels back into periodic model retraining to improve accuracy over time.
- Use graduated responses rather than binary block/allow decisions: low-confidence flags trigger a visible warning banner (e.g., 'external sender' or 'this domain does not match its usual sender'), while only high-confidence detections are auto-quarantined, reducing disruption from misclassified legitimate mail.
- Track precision, recall, and false-positive rate over time as the key metrics for validating that the new model is actually improving detection without excessively blocking legitimate business email.

Question 5: S/MIME Certificate Handling Vulnerabilities and Secure Certificate Management

A security audit found that encrypted email is vulnerable due to improper S/MIME certificate handling, requiring diagnosis of the specific weaknesses and a set of best practices for certificate management and trust validation.

A. Potential Certificate-Related Vulnerabilities

- Expired certificates continuing to be trusted because the mail client or gateway does not strictly enforce expiry checks.
- Private keys stored insecurely — for example, unencrypted on a laptop's local disk or protected only by a weak passphrase — creating risk of key theft if the device is compromised.
- Incomplete certificate chains presented by the sender (missing intermediate CA certificates), which can cause validation to fail unpredictably or, in lenient client configurations, be silently bypassed.
- Missing or ignored revocation checks (CRL/OCSP not queried, or queried with a 'soft-fail' policy that trusts the certificate anyway when the check is unreachable), allowing a compromised or revoked certificate to still be accepted.
- Certificate sharing or reuse across multiple users, which undermines the individual accountability and non-repudiation that S/MIME is meant to provide.

- Weak cryptographic parameters in older certificates still in circulation — such as RSA keys shorter than 2048 bits or signatures using the deprecated SHA-1 algorithm.

B. Trust Chain and Validation Process Analysis

A correct S/MIME validation process must check, in combination: that the certificate is within its validity period; that a complete chain exists from the end-entity certificate up to a trusted root; that each certificate in the chain is properly signed by its stated issuer; that the certificate has not been revoked (via CRL or OCSP); that its key usage/extended key usage includes email protection; and that the certificate's subject or Subject Alternative Name actually matches the sender's email address.

- Common failure point: mail clients configured to 'soft-fail' when an OCSP responder is unreachable, meaning a genuinely revoked certificate may still be accepted simply because the revocation check could not be completed.
- Common failure point: internally issued certificates from a private/internal CA whose root has not been properly distributed to all recipients' trust stores, causing legitimate internal certificates to appear untrusted (or, worse, users being trained to click through trust warnings, which erodes their ability to spot a genuinely malicious certificate).

C. Secure Certificate Storage and Management Practices

- Store private keys in hardware-backed secure storage — TPM modules, smart cards, or a Hardware Security Module (HSM) — rather than plain software-based key files, especially for high-value users handling sensitive transactions.
- Where software key stores must be used, enforce strong passphrase policies via centralized configuration (MDM/Group Policy) rather than leaving key protection to individual user discretion.
- Centralize the full certificate lifecycle — issuance, renewal reminders, and immediate revocation — and tie revocation directly into HR offboarding workflows so a departing employee's certificate is revoked the moment their access is terminated.
- Configure mail clients and gateways to perform hard-fail revocation checking (reject the certificate if CRL/OCSP cannot be verified) rather than soft-fail, closing the silent-bypass gap identified above.
- Conduct regular audits of the certificate inventory to identify and retire expired, orphaned, or weak-key certificates before they become an exploitable gap.

D. Improvements for User Awareness and System Configuration

- Train users to recognize the visual indicators of a validly signed or encrypted message (e.g., the signature/ribbon icon in the mail client) and to treat the unexpected absence of an expected signature as a warning sign, not a minor inconvenience.
- Configure mail clients to clearly warn — rather than silently accept — when a signature is invalid or a trust chain cannot be completed, instead of rendering the message as if nothing were wrong.
- Establish an organizational policy mandating S/MIME signing and/or encryption for specific high-risk message categories (e.g., wire transfer instructions, changes to payment details), with technical enforcement at the mail gateway.
- Run periodic security-awareness training covering certificate verification and how to report anomalies, and maintain an up-to-date trusted root store while proactively deprecating weak algorithms (SHA-1, sub-2048-bit RSA) organization-wide.

Overall Conclusion

Across all five industry scenarios, a consistent pattern emerges: security failures in IPSec and email systems typically arise not from a lack of available cryptographic tools, but from inconsistent configuration, manual key/certificate management, and incomplete validation logic. Standardizing on ESP with AEAD ciphers for IPSec, automating SA/key management via IKEv2 with certificate-based authentication, adopting S/MIME on top of enterprise PKI for regulated email communication, layering rule-based and ML-based detection for phishing, and enforcing strict, hard-fail certificate validation together address the practical gaps described in each case — directly supporting CO4's focus on implementing best practices for IP and email security through PGP and S/MIME.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation